COMPTE RENDU DU CHAP1_TP1.3 DE CYBERSECURITE

1. Introduction

1.1 Définition de la Threat Intelligence

La Threat Intelligence (ou renseignement sur les menaces) désigne le processus de collecte, d'analyse et d'exploitation d'informations relatives aux menaces informatiques potentielles ou actives ciblant un système d'information. Elle repose sur des données provenant de sources publiques, privées ou partagées entre organisations, et vise à transformer des données brutes en renseignements exploitables par les équipes de sécurité.

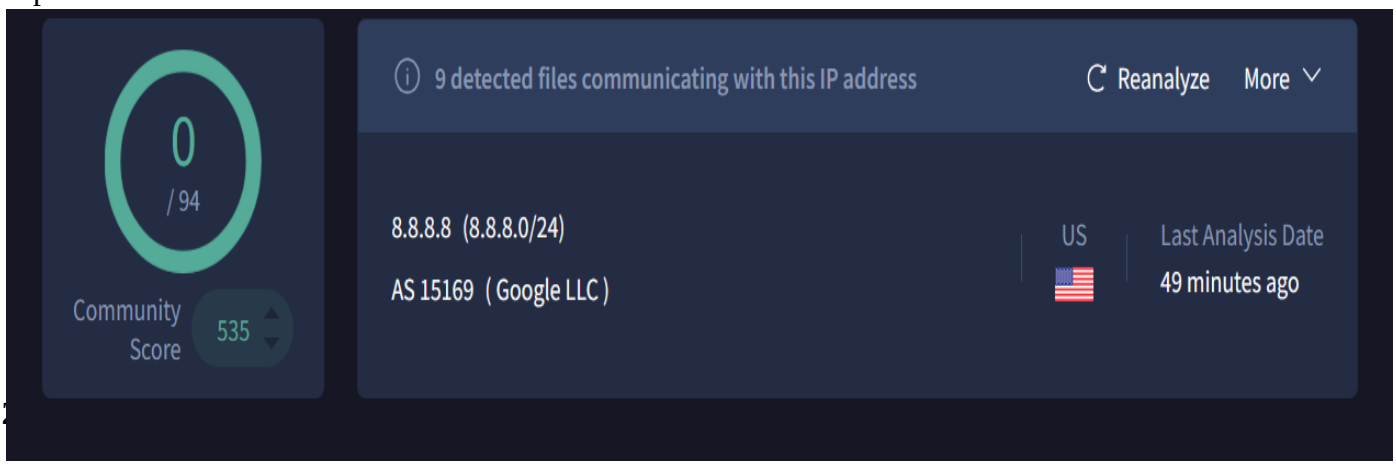
1.2 Rôle dans la cybersécurité

La Threat Intelligence joue un rôle central dans la posture défensive d'une organisation. Elle permet d'anticiper les attaques en identifiant les tactiques, techniques et procédures des attaquants avant qu'ils ne frappent.

Dans un contexte de SOC (Security Operations Center), la Threat Intelligence guide la priorisation des alertes, réduit les faux positifs et améliore le temps de réponse aux incidents. Elle constitue ainsi le socle d'une stratégie de cybersécurité proactive plutôt que réactive.

2. Analyse de l'adresse IP

Dans cette section, nous analysons l'adresse IP 8.8.8.8 de google. L'objectif est de déterminer si cette adresse est référencée comme malveillante dans les bases de données publiques de Threat Intelligence, notamment via la plateforme VirusTotal.



Le score affiché par VirusTotal représente le nombre de moteurs antivirus et d'outils de détection ayant signalé l'adresse IP comme malveillante sur le total de moteurs consultés. Un score de 0/94 indique

Rédiger par TEUTCHUENG Faustin Bienvenu

qu'aucun moteur ne considère cette adresse comme dangereuse à l'instant de l'analyse. En revanche, un score de 5/94 ou plus constitue un signal d'alerte sérieux nécessitant une investigation approfondie.

VirusTotal fournit également des métadonnées utiles : la géolocalisation de l'IP, le FAI hébergeur, les domaines associés, l'historique des détections ainsi que le numéro du système autonome(AS) auquel il appartient(AS15169 dans notre cas). Ces informations permettent de contextualiser la menace potentielle.

2.2 Conclusion sur la dangerosité

Sur la base des résultats obtenus, l'adresse IP analysée présente un niveau de risque à qualifier selon le score observé. Si l'adresse est propre (score 0), cela ne signifie pas l'absence totale de risque, car une machine saine peut être compromise à tout moment. Si des détections sont présentes, il convient d'isoler la machine du réseau et d'entamer une procédure de réponse à incident conformément à la politique de sécurité de l'organisation.

3. Analyse des services

Cette section présente les résultats du scan Nmap effectué sur le système Windows cible, l'identification des services vulnérables et la recherche des exploits correspondants à l'aide de l'outil searchsploit.

3.1 Résultat Nmap (TP 1.1)

Le scan Nmap a été exécuté avec la commande suivante afin d'identifier les ports ouverts, les services actifs et leurs versions sur la machine cible :

nmap -sV 192.168.56.40

```
┌──(faustin㉿faustin)-[~]
└─$ nmap -sV 192.168.56.40
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-13 05:10 +0200
Nmap scan report for 192.168.56.40
Host is up (0.0022s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 10.0p2 Debian 7 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.66 ((Debian))
MAC Address: 08:00:27:74:9F:94 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.
Nmap done: 1 IP address (1 host up) scanned in 10.03 seconds
```

3.2 Identification d'un service vulnérable

Parmi les services détectés par Nmap, le service Apache HTTP Server ressort comme particulièrement critique. Ce serveur web, fréquemment déployé sur les systèmes linux et Windows dans des configurations héritées, est associé à de nombreuses vulnérabilités documentées. La version identifiée lors du scan détermine précisément l'ensemble des CVE applicables.

D'autres services potentiellement vulnérables peuvent inclure SSH OpenSSH. Chaque port ouvert représente une surface d'attaque potentielle qu'il convient d'évaluer.

3.3 Capture searchsploit

La commande searchsploit permet d'interroger localement la base de données Exploit-DB afin de trouver des exploits publics correspondant aux services détectés. La commande utilisée est la suivante :*searchsploit apache*

```
┌──(faustin㉿faustin)-[~]
└─$ searchsploit Apache
--------------------------------------------- ---------------------------------
 Exploit Title                                |  Path
--------------------------------------------- ---------------------------------
Apache (Windows x86) - Chunked Encoding (Meta | windows_x86/remote/16782.rb
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Rem | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code | php/remote/29316.py
Apache - Arbitrary Long HTTP Headers (Denial  | multiple/dos/360.pl
Apache - Arbitrary Long HTTP Headers Denial o | linux/dos/371.c
Apache - Denial of Service                    | linux/dos/18221.c
Apache - httpOnly Cookie Disclosure           | multiple/remote/18442.html
Apache - Remote Memory Exhaustion (Denial of  | multiple/dos/17696.pl
Apache 0.8.x/1.0.x / NCSA HTTPd 1.x - 'test-c | cgi/remote/20435.txt
Apache 1.0/1.2/1.3 - Server Address Disclosur | multiple/remote/21067.c
Apache 1.1 / NCSA HTTPd 1.5.2 / Netscape Serv | multiple/dos/19536.txt
Apache 1.2 - Denial of Service                | multiple/dos/20558.txt
Apache 1.2.5/1.3.1 / UnityMail 2.0 - MIME Hea | windows/dos/20272.pl
Apache 1.3 + PHP 3 - File Disclosure          | multiple/remote/20466.txt
Apache 1.3 - Artificially Long Slash Path Dir | multiple/remote/20692.pl
Apache 1.3 - Artificially Long Slash Path Dir | multiple/remote/20693.c
Apache 1.3 - Artificially Long Slash Path Dir | multiple/remote/20694.pl
```

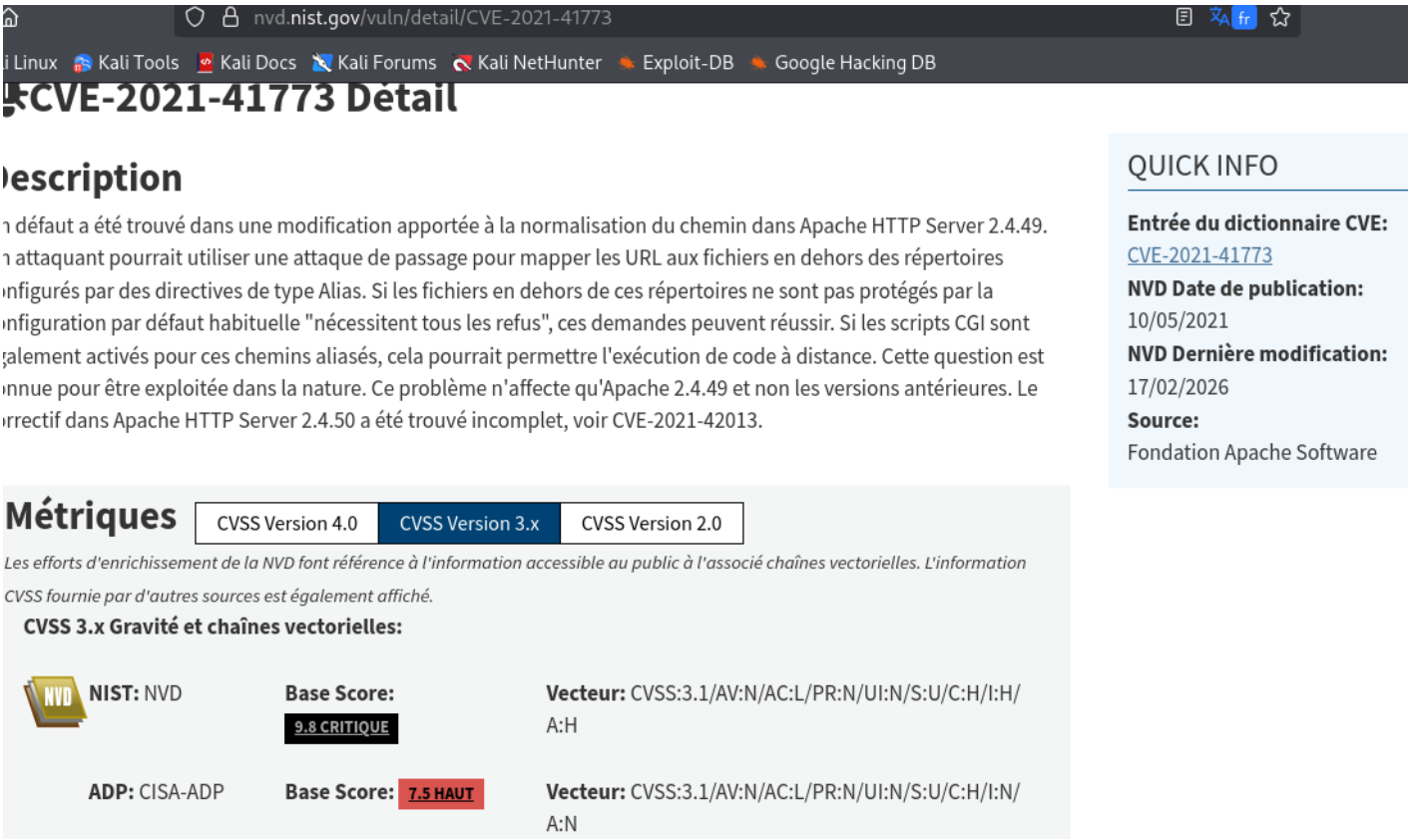
3.4 Explication des vulnérabilités identifiées

La sortie de searchsploit révèle plusieurs catégories de vulnérabilités affectant Apache. Les exploits de type Remote Code Execution (RCE) sont les plus critiques car ils permettent à un attaquant d'exécuter du code arbitraire sur le serveur distant sans authentification préalable. Les exploits de type Denial of Service (DoS) visent à rendre le service indisponible en saturant les ressources du serveur. Les vulnérabilités de type File Disclosure exposent des données sensibles (répertoires, versions, configuration) facilitant la phase

de reconnaissance. Chaque exploit est identifié par un numéro EDB-ID et peut correspondre à un ou plusieurs CVE officiels.

4. Étude d'une CVE (avec capture)

pour l'étude d'une CVE, nous rendons sur le site https://nvd.nist.gov et entrons la cve à étudier :



4.1 Description

CVE-2021-41773 est une vulnérabilité de type **Path Traversal** (traversée de répertoire) affectant exclusivement **Apache HTTP Server version 2.4.49**. Elle est causée par une validation insuffisante des entrées lors de la normalisation des chemins URL, permettant à un attaquant de faire pointer une URL vers des fichiers situés en dehors de la racine documentaire (*document root*) du serveurCVE-2021-41773 est une vulnérabilité de type **Path Traversal** (traversée de répertoire) affectant exclusivement **Apache HTTP Server version 2.4.49**. Elle est causée par une validation insuffisante des entrées lors de la normalisation des chemins URL, permettant à un attaquant de faire pointer une URL vers des fichiers situés en dehors de la racine documentaire (*document root*) du serveur. **En clair :** un attaquant envoie une requête HTTP spécialement forgée avec des caractères encodés (ex. `%2e%2e/` au lieu de `../`) pour sortir du répertoire web autorisé et accéder à des fichiers système sensibles.

4.2 Impact

L'impact est double selon la configuration du serveur :

a) Divulgation d'information La vulnérabilité permet d'accéder à des fichiers sensibles en dehors du document root.

b) Exécution de code à distance Bien que le CVE-2021-41773 était qualifier de simple bug de divulgation d'informations, des chercheurs indépendants ont confirmé que la vulnérabilité peut être utilisée pour de l'exécution de code à distance.

Sur le plan des **triade CIA** :

- **Confidentialité** : compromise (accès à des fichiers privés)
- **Intégrité** : compromise si RCE possible (modification de fichiers)
- **Disponibilité** : compromise (risque de prise de contrôle totale du serveur)

4.3 Niveau de gravité

Le score CVSS de base est de 7.5 (HIGH), mais en présence du module mod_cgi activé, l'exploitation en RCE fait monter la criticité à 9.8 (CRITICAL). Cette vulnérabilité a été exploitée comme zero-day avant même la publication du patch officiel.

4.4 Exploitation possible

L'exploitation peut être réalisée manuellement via une requête curl ou avec Metasploit en utilisant les deux vecteur mentionner plus dans la capture d'écran.

5. Utilisation avancée de searchsploit

Searchsploit dispose de plusieurs options avancées permettant d'affiner la recherche, d'inspecter le code source des exploits et de les copier dans le répertoire de travail. Nous présentons ici trois options essentielles pour un usage professionnel.

Option 1 — searchsploit -x <chemin>

Rôle :

L'option -x (eXamine) permet d'afficher directement dans le terminal le contenu du fichier d'exploit sans avoir à le copier au préalable. Elle ouvre le fichier en lecture seule dans un paginateur (less), ce qui permet d'analyser rapidement le code source, de comprendre le mécanisme d'exploitation et d'identifier les prérequis nécessaires.

Exemple d'utilisation :

searchsploit -x php/remote/29290.c

Utilité : Très utile lors de la phase d'analyse pour comprendre un exploit avant de décider de l'utiliser. Permet de vérifier la compatibilité avec la cible (OS, version du service) et d'identifier les paramètres à adapter sans modifier le fichier original.

Option 2 — searchsploit -m <id>

Rôle :

L'option -m copie l'exploit sélectionné dans le répertoire de travail courant. Contrairement à -x qui affiche seulement, -m crée une copie locale modifiable du fichier.

Exemple d'utilisation :

searchsploit -m 29290

```
┌──(faustin㉿faustin)-[~]
└─$ searchsploit -m 34
  Exploit: Webfroot Shoutbox < 2.32 (Apache) - Local File Inclusion / Remote Cod
e Execution
      URL: https://www.exploit-db.com/exploits/34
     Path: /usr/share/exploitdb/exploits/linux/remote/34.pl
    Codes: OSVDB-15391
 Verified: True
File Type: Perl script text executable
Copied to: /home/faustin/34.pl
```

Utilité : Indispensable quand on souhaite adapter le code de l'exploit à un contexte spécifique (modification de l'IP cible, du port, des paramètres d'authentification). Le fichier copié peut ensuite être compilé, modifié et exécuté dans un environnement de test contrôlé.

Option 3 — searchsploit apache 2.4

Rôle :

Cette syntaxe de base permet de rechercher tous les exploits disponibles pour un service donné et une version spécifique.

Exemple d'utilisation :

searchsploit apache 2.4.66

```
┌──(faustin㉿faustin)-[~]
└─$ searchsploit Apache 2.4.66
--------------------------------------------- ---------------------------------
 Exploit Title                                |  Path
--------------------------------------------- ---------------------------------
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Rem | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code | php/remote/29316.py
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of S | multiple/dos/26710.txt
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' | unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2. | unix/remote/47080.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2. | unix/remote/764.c
Apache OpenMeetings 1.9.x < 3.1.0 - '.ZIP' Fi | linux/webapps/39642.txt
Apache Tomcat < 5.5.17 - Remote Directory Lis | multiple/remote/2061.txt
Apache Tomcat < 6.0.18 - 'utf8' Directory Tra | multiple/remote/6229.txt
Apache Tomcat < 6.0.18 - 'utf8' Directory Tra | unix/remote/14489.c
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8 | jsp/webapps/42966.py
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8 | windows/webapps/42953.txt
Apache Xerces-C XML Parser < 3.1.2 - Denial o | linux/dos/36906.txt
Webfroot Shoutbox < 2.32 (Apache) - Local Fil | linux/remote/34.pl
--------------------------------------------- ---------------------------------
Shellcodes: No Results
```

Utilité :

Permet d'établir rapidement une liste de toutes les vulnérabilités publiquement connues pour un service bien ciblé..

6. Analyse globale de sécurité

6.1 Risques identifiés

L'analyse combinée du scan Nmap, de VirusTotal et de searchsploit permet d'identifier plusieurs risques :

– Risque de déni de service (DoS) : plusieurs exploits référencés permettent de saturer le service Apache et de le rendre indisponible, impactant la continuité d'activité.

– Risque de divulgation d'informations : des vulnérabilités d'Information Disclosure exposent la structure interne du serveur (répertoires, version, configuration), facilitant les attaques ultérieures.

– Risque lié aux services port.

6.2 Service le plus dangereux

Le service le plus dangereux identifié est Apache HTTP qui écoute sur le port 80 qui est un port ouvert.

6.3 Actions recommandées

- Mettre à jour immédiatement Apache et PHP vers les dernières versions stables afin d'éliminer les CVE connues.
- Désactiver les services non nécessaires pour réduire la surface d'attaque.
- Effectuer des audits de sécurité réguliers (pentest, scan de vulnérabilités) pour détecter les nouvelles failles avant qu'elles ne soient exploitées.

7. Lien avec l'entreprise

7.1 Comment un SOC utilise la Threat Intelligence

Dans un Security Operations Center (SOC), la Threat Intelligence est intégrée à plusieurs niveaux du processus de surveillance et de réponse aux incidents. Les analystes du SOC utilisent des plateformes de Threat Intelligence pour centraliser et partager les indicateurs de compromission.

Concrètement, les flux de Threat Intelligence (IP malveillantes, domaines suspects, hashes de fichiers malicieux) sont injectés directement dans les plarteformes afin d'enrichir automatiquement les alertes.

7.2 Comment anticiper une attaque

L'anticipation des attaques repose sur un cycle continu de renseignement : collecte, analyse, diffusion. En amont, la veille sur les nouvelles CVE publiées permet d'identifier les vulnérabilités critiques avant qu'elles ne soient activement exploitées dans la nature.

8. Conclusion

8.1 Ce que nous avons appris

Ce travail pratique nous a permis d'acquérir une approche méthodologique complète de l'analyse de sécurité, depuis la collecte de renseignements sur une adresse IP via VirusTotal jusqu'à l'identification des vulnérabilités exploitables avec searchsploit. La maîtrise de la chaîne d'outils Nmap → searchsploit → recherche de CVE constitue le socle technique d'un analyste en sécurité offensive. Chaque outil joue un rôle précis : Nmap pour la découverte, searchsploit pour la recherche d'exploits, et les bases CVE pour la qualification et la priorisation des risques.

8.2 Limites de l'analyse

Premièrement la présence d'un exploit dans la base de données ne signifie pas automatiquement qu'il est fonctionnel contre la cible : la configuration spécifique du système (pare-feu, IDS) peut rendre l'exploitation impossible ou nécessiter des adaptations importantes. Une analyse approfondie requiert toujours une phase de validation en environnement de test avant toute tentative sur une cible réelle.

Troisièmement, VirusTotal ne détecte que les IPs déjà connues et référencées par les éditeurs de sécurité. Une adresse IP récemment compromise ou un malware personnalisé peut ne pas être signalé, conduisant à une évaluation de risque sous-estimée.